Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-28 09:00 WIB

Top 5 Highlights

- Introducing Route 53 Resolved IP Validation for AWS Network Firewall
- Japan's GMO urges customers to shut down PCs amid ransomware threat
- Engie confirms customer data breach via marketing platform
- China-linked Warlock ransomware group targets global infrastructure
- Japanese ISP GMO Internet suffers major data breach and ransomware demand

Threat Intelligence (10)

01. Introducing Route 53 Resolved IP Validation for AWS Network Firewall

Your workloads reach most destinations by domain name, but a firewall can only act on what it sees in the traffic. For HTTP and HTTPS, AWS Network Firewall domain rules match the name that the client puts in the request, and the client chooses that name. The connections for protocols such as SSH and SSH […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://aws.amazon.com/blogs/security/introducing-route-53-resolved-ip-validation-for-aws-network-firewall/

02. External Teams Chats Anchor 15-Minute Malware Delivery

Main bombing sis getting a new look with a wide-scale, ongoing social engineering campaign that might be tied to the Black Basta ransomware gang.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/cloud-security/email-bombing-external-teams-chats-repeatable-access-path

03. SBOMs Alone Can't Reveal the Scope of a Supply Chain Attack

A recent Shai-Hulud attack shows defenders need real-time visibility into production code and affected services to respond to supply chain compromises.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.darkreading.com/cyber-risk/sboms-alone-scope-supply-chain-attack

04. 'Aokigahara' Stealer Targets 'Developer Keyrings' & AI Assistants

The malware's focus on AI tools expands the traditional infostealer playbook to expose a forest of AI sessions, sensitive business data, and developer infrastructure from a single compromised endpoint.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/endpoint-security/aokigahara-stealer-developer-keyrings-ai-assistants

05. Hackers Infect 953 Online Stores With Scanner-Evading Code

Attackers have infected 953 online stores with a scanner-evading JavaScript loader since July 2025

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.infosecurity-magazine.com/news/hackers-infect-953-online-stores/

06. Tricks from the Past deployed via signed ChatGPT and Claude binaries

Key Points Introduction Over the past two months, we have been tracking a campaign that abuses the popularity of AI tools such as ChatGPT and Claude to spread a custom malware chain we call Yoba. The attackers use fake GitHub projects that pretend to be AI desktop applications like GPT-5.6 Sol, GPT-6 Astra, and Claude […] The post Tricks from the Past deplo…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://research.checkpoint.com/2026/tricks-from-the-past-deployed-via-signed-chatgpt-and-claude-binaries/

07. Introducing the Cloudflare PHP Capture the Flag challenge

We are launching a PHP Capture the Flag challenge integrated with our Bug Bounty program to test our WAF protections. Security researchers are invited to bypass our defenses and capture the flag to help make the Internet safer.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://blog.cloudflare.com/php-ctf/

08. AI-Generated Fake Login Pages Are Making Account Takeovers Easier

Fake login pages are nothing new, but generative AI is making them easier to build and more convincing. Attackers can recreate familiar login screens, impersonate trusted brands and tailor phishing attempts to specific employees or organizations. Some fake login pages go beyond stealing passwords. They can also capture MFA codes or hijack authenticated sess…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://thehackernews.com/2026/10/ai-generated-fake-login-pages-are.html

09. Lazarus Abuses South Korean Security Software to Deploy Malware Using Post-Quantum Encryption

The North Korea-linked Lazarus Group has been attributed to a cyber espionage campaign dubbed Operation FlashHole targeting at least three organizations in South Korea spanning the construction, software, and wire-communication equipment manufacturing sectors. According to Russian cybersecurity company Kaspersky, the campaign has been active since at least…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/lazarus-abuses-south-korean-security.html

10. [+24h Old] Australia Gets Into Amadey Malware Backend, Cuts Off Access to 180,000 Infected Computers

A criminal using the Amadey malware can no longer access or steal data from 180,000 infected computers around the world, including some in Australia, the Australian Signals Directorate (ASD) says. The agency's operators gained access to the criminal's operation's backend and cut it off from those computers. "The next steps that we took were to disconnect th…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/australia-gets-into-amadey-malware.html

Latest Vulnerabilities (10)

01. Hackers hijack Convertr analytics script to steal payment card data

A credit card skimming group reportedly compromised a shared analytics script used by e-commerce platform Convertr to steal shoppers' payment data during checkout. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/hackers-hijack-convertr-analytics-script-to-steal-payment-card-data/

02. Brotli bug reaches far beyond Node.js (CVE-2026-111497)

A vulnerability in Brotli, Google’s widely used open-source compression library, is putting a broad range of software at risk. About CVE-2026-111497 Alternatively known as “Node2Shell”, “Broccoli2Shell” and “Brotli2Shell”, CVE-2026-111497 is a remotely exploitable out-of-bounds write flaw that gained widespread attention after Node.js

publicly disclosed it…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.helpnetsecurity.com/2026/10/27/node2shell-broccoli2shell-vulnerability-cve-2026-111497/

03. Cyber Incident Forces UNM Health to Cancel Surgeries, Divert Ambulances

The University of New Mexico is working to restore systems following the incident, which has been claimed by the BYOD ransomware group

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.infosecurity-magazine.com/news/cyber-unmhealth-surgeries/

04. Tailscale Rushes Patches After Uncoordinated Disclosure of ‘Tailworm’ Flaws

Tailscale is preparing a patch for Tailscale SSH flaws whose details went public over the weekend, before any fixes had been released. The post Tailscale Rushes Patches After Uncoordinated Disclosure of ‘Tailworm’ Flaws appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.securityweek.com/tailscale-rushes-patches-after-uncoordinated-disclosure-of-tailworm-flaws/

05. ISC2 Launches Cyber-AI Workforce Coalition to Address the Future of AI Security Jobs

ISC2’s new Cyber-AI Workforce Coalition serves as a “vendor-neutral convener” to map the future of AI security careers, ISC2 CEO Scott Beale told Infosecurity

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.infosecurity-magazine.com/news/isc2-launches-cyberai-workforce/

06. CISA confirms PHP2Shell under attack as researchers clock successful exploits

Both critical PHP flaws land on the agency’s exploited list as infosec pros confirm hackers are getting working shells

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/cyber-crime/2026/10/27/cisa-confirms-php2shell-under-attack-as-researchers-clock-successful-exploits/5305681

07. Tailscale warns of SSH flaws allowing root privilege escalation

The Tailscale security team is working to patch almost a dozen security vulnerabilities that could be exploited to steal credentials, crash servers, gain root privileges, and more. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/tailscale-warns-of-serious-ssh-flaws-allowing-root-privilege-escalation/

08. SkyW4lker Exposed: A Growing Microsoft 365 Phishing Threat to American Enterprises

SkyW4lker (SkyW4lker x365 Sentinel) is an active device-code phishing kit targeting Microsoft 365 users in the United States, Europe, and other regions. By abusing Microsoft’s legitimate authentication process, the kit can give attackers access to corporate accounts without stealing passwords or bypassing MFA. This puts business emails, sensitive documents,…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://any.run/cybersecurity-blog/skyw4lker-phishing-kit-analysis/

09. Apple Backports Fix for Exploited CoreGraphics Flaw to Older iPhones and iPads

Apple on Monday backported fixes for a high-severity security flaw that was exploited in real-world cyber attacks to older devices. The vulnerability, tracked as CVE-2026-86950 (CVSS score: 8.8), is an out-of-bounds write affecting CoreGraphics that could result in arbitrary code execution when processing a maliciously crafted file. Patches for the flaw wer…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/apple-backports-fix-for-exploited.html

10. HPE Patches Dozens of Critical Flaws in Networking Products

Eight max-severity security defects could lead to remote code execution and authentication bypass. The post HPE Patches Dozens of Critical Flaws in Networking Products appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.securityweek.com/hpe-patches-dozens-of-critical-flaws-in-networking-products/

Data Breach & Cybercrime (10)

01. Japan's GMO urges customers to shut down PCs amid ransomware threat

The GMO Group has urged customers to disconnect their systems from the internet and shut down computers after a threat actor who breached the company's Onamae Desktop Cloud threatened to launch a ransomware attack today. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.bleepingcomputer.com/news/security/japans-gmo-urges-customers-to-shut-down-pcs-amid-ransomware-threat/

02. Engie confirms customer data breach via marketing platform

Per Bleeping Computer, French energy provider Engie recently confirmed that unauthorized actors accessed customer data following a security breach of a marketing platform utilized by its business partners.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/engie-confirms-customer-data-breach-via-marketing-platform

03. China-linked Warlock ransomware group targets global infrastructure

As reported by cyberscoop, the China-linked threat group known as Storm-2603, which operates the Warlock ransomware, has launched a series of targeted attacks against at least four organizations across Europe, Africa and Latin America.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.scworld.com/brief/china-linked-warlock-ransomware-group-targets-global-infrastructure

04. Japanese ISP GMO Internet suffers major data breach and ransomware demand

As detailed in The Register, Japanese internet service provider GMO Internet has confirmed a significant security breach affecting its Onamae.com Desktop Cloud service.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.scworld.com/brief/japanese-isp-gmo-internet-suffers-major-data-breach-and-ransomware-demand

05. University of Copenhagen reports data breach affecting over 500,000 individuals

Bleeping Computer reports that the University of Copenhagen recently confirmed a cyberattack involving unauthorized access to a test environment containing the personal data of 525,000 people.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/university-of-copenhagen-reports-data-breach-affecting-over-500000-individuals

06. UNM Health ransomware attack disrupts patient care, surgeries

The University of New Mexico Health Sciences Center disclosed a cyberattack that caused system outages and disrupted patient care and academic activities. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.bleepingcomputer.com/news/security/unm-health-ransomware-attack-disrupts-patient-care-surgeries/

07. Warp discloses breach exposing AI agent logs, user telemetry data

Agent decision logs and telemetry data belonging to Warp agentic development environment users were exposed in an attack on a third-party vendor in the project's infrastructure. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/warp-discloses-breach-exposing-ai-agent-logs-user-telemetry-data/

08. Five election scams to watch out for

Election messages can ask you to register, donate, take a survey, or buy merchandise. Here’s how to check before you click or pay.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/scams/2026/10/five-election-scams-to-watch-out-for

09. Vendor Key Leak Puts Data of 238,000 Denver Health Plan Members at Risk

A leaked SquareML access key could have been used to access a database containing personal and health information. The post Vendor Key Leak Puts Data of 238,000 Denver Health Plan Members at Risk appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/vendor-key-leak-puts-data-of-238000-denver-health-plan-members-at-risk/

10. Exeon expands threat detection to shadow AI and autonomous agents

Exeon Analytics has introduced Exeon.AgentGuard, a new AI security solution designed to give organizations visibility into approved and shadow AI use, autonomous agent activity and the data flows created through connected tools and external services. Building on its expertise in AI-driven behavioral analytics and threat detection, Exeon expands its cybersec…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/10/27/exeon-expands-threat-detection-to-shadow-ai-and-autonomous-agents/